비밀번호·인증수단 관리 규정

제1장 일반 원칙

제1조(목적)

회사 계정의 비밀번호, 다중인증(MFA), 복구수단 및 계정 잠금과 관련된 준수사항을 정한다.

제2조(적용)

임직원·승인된 외부자의 회사 통합 계정, 업무시스템 계정 및 원격접속 인증에 적용한다. 업무 서비스별 기술 구현은 시스템 소유자 및 IT지원팀이 담당한다.

제3조(본인 계정)

자격증명은 본인만 사용하며 공용 문서·메신저·티켓에 저장하거나 타인에게 전달해서는 안 된다. 관리자·서비스계정은 별도 승인과 사용 추적을 적용한다.

제2장 생성·변경·복구

제4조(비밀번호)

회사는 안전한 길이와 유출 여부 탐지를 바탕으로 암호 생성 기준을 운영한다. 임의로 반복 사용하거나 유출이 의심된 암호를 재사용하지 않는다.

제5조(변경 및 잠금)

계정 탈취 의심이나 관리자 요구가 발생하면 안전한 채널로 암호를 변경하고 기존 세션·복구수단의 보호상태를 확인한다. 인증 실패 반복은 서비스 정책에 따라 접근을 제한한다.

제6조(다중인증)

업무 중요도와 위험에 따라 승인된 MFA를 적용한다. 인증 요청 알림을 본인이 시작하지 않았다면 거절하고 이상 징후를 신고한다.

제7조(복구 절차)

분실·기기 변경 등으로 인증이 불가능하면 승인된 본인확인 및 복구 절차를 따른다. 이름과 사번만 묻는 방식이나 기존 비밀번호·일회용코드 제출을 본인확인의 유일한 수단으로 삼지 않는다.

제3장 책임과 예외

제8조(관리자 역할)

IT지원팀은 정책에 따라 인증수단을 기술적으로 재설정하되 사용자 비밀값을 수집·열람하지 않는다. 정보보안팀은 위험 기반의 복구·예외 적정성을 검토한다.

제9조(인증수단 분실)

등록한 휴대전화·하드웨어 키 등 인증수단을 분실하면 즉시 등록 해제와 계정 보호를 신청한다. 기기 분실은 SEC-073 절차도 따른다.

제10조(예외 통제)

MFA를 임의로 해제하는 대신 회사가 승인한 대체 인증 경로를 검토한다. 불가피한 예외에는 기간·범위·대체통제와 승인을 기록한다.

업무 처리 기준 및 확인 사항

별표 1. 인증 관련 상황별 담당

상황	직원	기술 담당
비밀번호 분실	공식 복구 신청	IT지원팀 본인확인 후 처리
모르는 MFA 승인 요청	거부·신고	정보보안팀 조사
인증수단 분실	즉시 신고	IT지원팀 등록 회수
관리자 특권 접근	사전 승인	시스템 소유자 및 보안 검토

부칙

제1조(시행일) 이 규정은 2026년 10월 01일부터 시행한다.